개인정보의 식별/분류/보안/관리에 대한 방안

기업과 기관의 개인정보 보안 대응 실전

2026. 09

파수 AI 김규봉 본부장

FASOO | AI

새로운 환경의 변화

데이터의 파편화	생성형 AI	법령 강화
클라우드 / 온프레미스 SaaS / PC	ChatGPT, Gemini, Claude, Co-pilot	개정된 개인정보보호법
		
데이터는 이제 어느 한곳이 아닌 내 PC, 클라우드 등 보관 장소 경계의 붕괴	생성형 AI 등장에 따른 무분별한 데이터 외부 유출	기업/기관 존립 위협 수준의 제재 개인정보 보호책임자 독립성 강화 ISMS-P 인증 개인정보 유출 통지 의무

AI시대는 **새로운 개인정보 관리 패러다임**이 필요합니다.

Copyrightⓒ Fasoo AI All Rights Reserved.

오늘, 3가지만 가져가시면 됩니다

STEP 1 · 분류 식별	STEP 2 · 차등 보호	STEP 3 · 태세 관리
문맥을 읽는 AI 검출	**C/S/O 등급별 암호화**	**멈추지 않는 감시**
		
정규식이 놓치는 개인정보까지 전수 스캔으로 찾아냅니다	기밀은 강하게 잠그고, 공개 등급은 AI에 개방합니다	클라우드 · SaaS의 섀도우 데이터를 상시 추적해 72시간에 대응합니다

세 단계는 한번에 끝나는 것이 아닌 계속적으로 맞물려 돌아갑니다.

Copyrightⓒ Fasoo AI All Rights Reserved.

FASOO | AI

기업과 기관의 개인정보 보안 대응 실전

분류 식별

Copyright© Fasoo AI All Rights Reserved.

FASOO | AI

법도 '식별'에서 시작합니다 - 안전조치의무 제29조

개인정보보호법 제29조의 안전조치의무는

보유 개인정보의 현황 파악을 전제로 합니다.

무엇이 어디에 있는지 모르면, 어떤 보호조치도 시작할 수 없습니다.

- 감사 · 실사 대응의 기본 — 개인정보 데이터 맵 확보
- AI 학습 · 활용 전 고유식별정보 사전 선별 → 최소 수집·목적 제한 원칙 (제3조 · 제16조) 실현

Copyright© Fasoo AI All Rights Reserved.

현재의 분류 식별 메카니즘

정규표현식 (RegEX) 기반



주민등록번호, 전화번호, 이메일, 계좌번호 등 고정된 숫자/문자 패턴 스캐닝

키워드 검색



'대외비', '기밀', '개인정보' 등 지정 단어 포함 여부 단층 분석

메타데이터 및 확장자



생성자, 작성일, .pdf, .hwpx 등 단순 파일 속성을 기준

정적 (Static) 규칙



보안 담당자가 규칙과 예외 패턴을 수동으로 관리

단순 숫자, 문자 조합에 따른 식별로 인한 **오탐, 과탐**의 문제를 해결 할 수 없으며,
계약서, 회의록, 상담 일지 등 자유서식에 포함된 개인정보를 탐지하기 어렵고,
띄어쓰기, 변형 문자, 이미지 내 텍스트에 대한 식별도 어렵습니다.

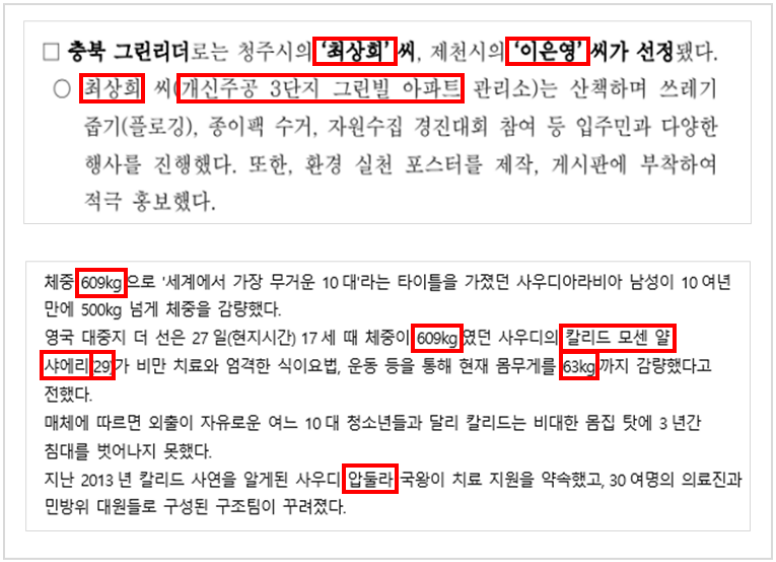
Copyright© Fasoo AI All Rights Reserved.

키워드 검색은 문맥 속 개인정보를 놓칩니다

기존 개인정보 검출방식 - 정규표현식

주민등록번호	(₩d{6}[,-]-?[1-4]₩d{6})|(₩d{6}[,-]?[1-4])
운전면허번호	(₩d{2}-₩d{2}-₩d{6}-₩d{2})
전화번호	(₩d{2,3}[,-]-?₩d{2,4}[,-]-?₩d{4})
이메일	(([₩w!-_₩.])*@([₩w!-_₩.])*₩.[₩w]{2,3})
나이/생년월일	(₩d{0,4}(년생|월생|세|살))
여권번호	([a-zA-Z]{1}|[a-zA-Z]{2})₩d{8}
계좌번호	([0-9,₩-]{3,6}₩-[0-9,₩-]{2,6}₩-[0-9,₩-])
건강보험번호	[1257][-~.[:space:]][0-9]{10}

정규표현식으로 검출하지 못한 개인정보 — 실제 예시



□ **충북 그린리더**로는 청주시의 **'최상희'씨**, 제천시의 **'이은영'씨가 선정**됐다.

○ 최상희 씨(개신주공 3단지 그린빌 아파트 관리소)는 산책하며 쓰레기 줍기(플로깅), 종이팩 수거, 자원수집 경진대회 참여 등 입주민과 다양한 행사를 진행했다. 또한, 환경 실천 포스터를 제작, 게시판에 부착하여 적극 홍보했다.

체중 609kg으로 '세계에서 가장 무거운 10 대'라는 타이틀을 가졌던 사우디아라비아 남성이 10 여년 만에 500kg 넘게 체중을 감량했다.

영국 대중지 더 선은 27 일(현지시간) 17 세 때 체중이 609kg였던 사우디의 칼리드 모센 알 샤에리 29가 비만 치료와 엄격한 식이요법, 운동 등을 통해 현재 몸무게를 63kg까지 감량했다고 전했다.

매체에 따르면 외출이 자유로운 여느 10 대 청소년들과 달리 칼리드는 비대한 몸집 탓에 3 년간 침대를 벗어나지 못했다.

지난 2013 년 칼리드 사연을 알게된 사우디 압둘라 국왕이 치료 지원을 약속했고, 30 여명의 의료진과 민방위 대원들로 구성된 구조팀이 꾸려졌다.

문장 속 이름 · 주소 · 나이 — 패턴이 없는 개인정보는 **문맥을 읽어야만** 잡힙니다.

Copyright© Fasoo AI All Rights Reserved.

식별 - 문맥을 읽어야 개인정보가 보입니다

- PC (Windows·macOS) · 서버 · 스토리지 전수 스캔
- 딥러닝 언어모델이 문맥을 이해해 검출
- 텍스트 · 오피스 문서 · 이미지 (OCR)까지 커버
- 검출 즉시 마스킹·비식별 또는 등급 분류

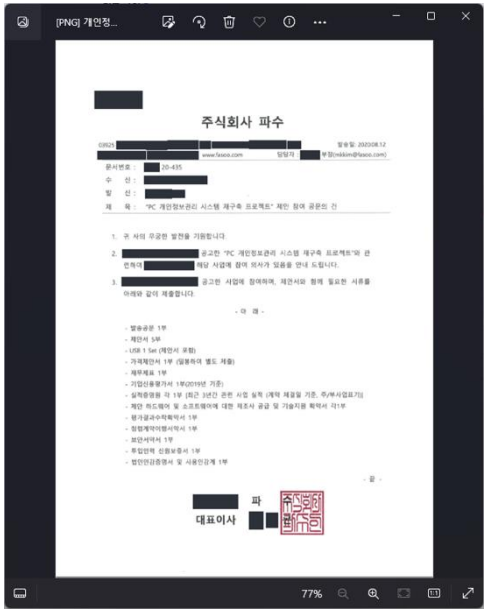
Fasoo Data Radar
민감정보 분류 식별 및 통제 관리

+

AI-R Privacy
AI 기반 데이터 검출 및 마스킹

* 다수의 공공기관 및 금융권 및 일반기업을 통해 기술력이 입증 되었습니다.
(대법원 판결문에 대한 개인정보 마스킹을 별도의 GPU 없이 하루 평균 3만건 이상 처리)

AI 검출 · 마스킹 결과 — 실제 화면



Copyright© Fasoo AI All Rights Reserved.

공공은 이미 움직였습니다 - 국가 망 보안체계(N2SF)

20년의 망분리가 클라우드·AI의 걸림돌이 되자, 국가정보원은
C (기밀) · S (민감) · O (공개) 등급 차등 통제로 전환했습니다.

<업무정보 C/S/O 등급 분류 기준>

등급	등급분류 기준
기밀 (C)	• **정보공개법 제9조(비공개 대상 정보)의 제1호~제4호** - 비밀, 안보 · 국방 · 외교 · 수사 등 기밀정보 및 국민 생활 · 생명 · 안전과 직결된 정보
민감 (S)	• **정보공개법 제9조(비공개 대상 정보)의 제5호~제8호** - 비공개 정보로 개인·국가 이익 침해가 가능한 정보
공개 (O)	• **공공데이터법(제2조)에 따른 공공데이터로 기밀(C)·민감(S) 정보 이외의 정보** - 관련 법령에 규정된 정보 공개 요건을 충족한 비공개 정보 또는 기간의 경과 등으로 비공개 필요성이 소멸된 정보 포함

Copyright© Fasoo AI All Rights Reserved.

업무 환경에 맞는 CSO 분류

20년의 망분리가 클라우드·AI의 걸림돌이 되자, 국가정보원은
C (기밀) · S (민감) · O (공개) 등급 차등 통제로 전환했습니다.

<분류 방식>



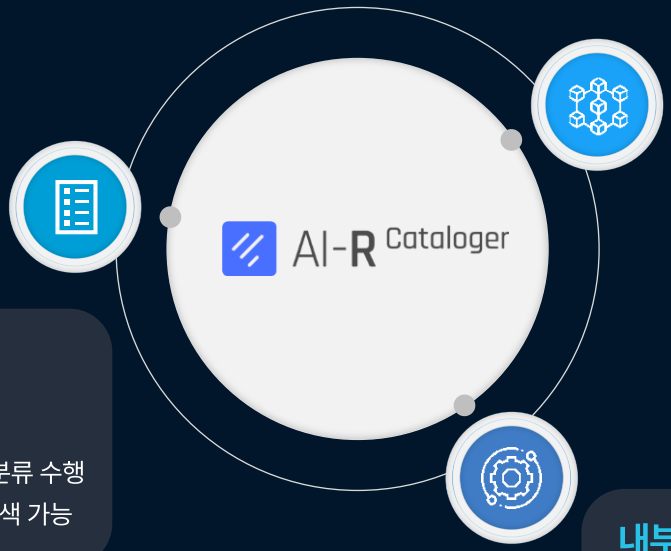
분류 주체	내용	예시
사용자 선택	사용자가 문서 생성시 등급 선택	워드 작성 시 'C' 선택 시 암호화 자동 적용
시스템 연동	문서 다운로드 시 출처, 경로 기반 분류	내부 업무 시스템에서 다운로드 받은 문서 → 'S' 자동 라벨
내용 기반 자동 분류	키워드, 패턴 기반 자동 분류 문서의 의미와 맥락에 따른 자동 분류	개인정보, 계약정보 키워드 포함 시 'S' 분류 기관내의 비공개 연구 정보 포함 시 'S' 분류

Copyrightⓒ Fasoo AI All Rights Reserved.

FASOO AI

비정형 데이터의 분류 식별은?

관리되고 있는 시스템 내의 분류 식별은 가능하지만,
개인 PC 혹은 비관리된 파일에 대한 분류 식별은 어렵습니다.



유사도 기반

- 문서를 문맥 단위로 청킹해 분석 수행
- 분류할 문서와 학습된 고객사의 기준의 유사도 비교 수행
- 유사도 분석 이후, 내부 LLM이 문장 확인 후 분류 진행

키워드 · 정규식 기반

- 키워드 및 정규식 기반 검출 패턴 적용
- 특정 단어, 어휘 등을 통해 빠르게 문서 분류 수행
- 의미가 유사하지만, 형태가 다른 단어 탐색 가능

내부 업무 분류 기준 활용

- 기업 내부의 업무 분류와 산출물 기준으로 문서 분류 기준 설정
- BRM (Business Relation Model) 등을 활용해 내부 업무 분류
- 이외 주요 키워드, 메타 데이터, 특정 문장을 학습 데이터로 활용 가능

Copyright© Fasoo AI All Rights Reserved.

기업과 기관의 개인정보 보안 대응 실전

차등 보호

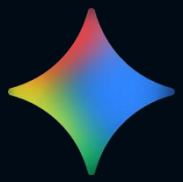
Copyright© Fasoo AI All Rights Reserved.

FASOO | AI

생성형 AI는 이미 업무 한복판에 있습니다

업무 생산성은 올랐지만, **데이터의 경계**는 사라졌습니다.


ChatGPT


Gemini


Claude


Copilot

프롬프트와 첨부파일이 새로운 유출 경로가 되고,

문서는 개인 PC · 클라우드 · SaaS로 흩어져 **섀도우 데이터**가 쌓입니다.

Copyright© Fasoo AI All Rights Reserved.

그렇다고 전부 잠그면, 이번엔 AI가 멈춥니다

전사 일괄 암호화는 **LLM 인덱싱과 RAG를 불가능**하게 만들고,

불편해진 직원들은 **통제 밖의 우회 경로**를 만들어냅니다.

보안을 지키려던 조치가 **보안 사각지대와 AI 정체**를 동시에 낳는 역설입니다.

필요한 것은 '전부 아니면 전무'가 아니라, 데이터 등급에 따른 차등 통제입니다.

Copyright© Fasoo AI All Rights Reserved.

차등 보호는 법이 허용한 방식입니다



안전성 확보조치 기준 제7조 - 고유식별정보·비밀번호의 암호화 의무를 이행하되,

위험분석에 근거한 차등 보호조치로 낮은 위험 등급은 합법적으로 개방할 수 있습니다.

- 유출 사고 시 암호화 이행 '증적'이 핵심 감경 요소
- Open 등급의 비암호화 활용 — 위험분석 문서로 정당성·감독기관 증빙 확보

Copyright© Fasoo AI All Rights Reserved.

보호 : 모든 데이터가 같을 필요는 없습니다

N2SF의 **C/S/O 3등급**을 기업 데이터에 준용합니다
등급 판정은 Step 1의 식별 결과가 자동 공급합니다.

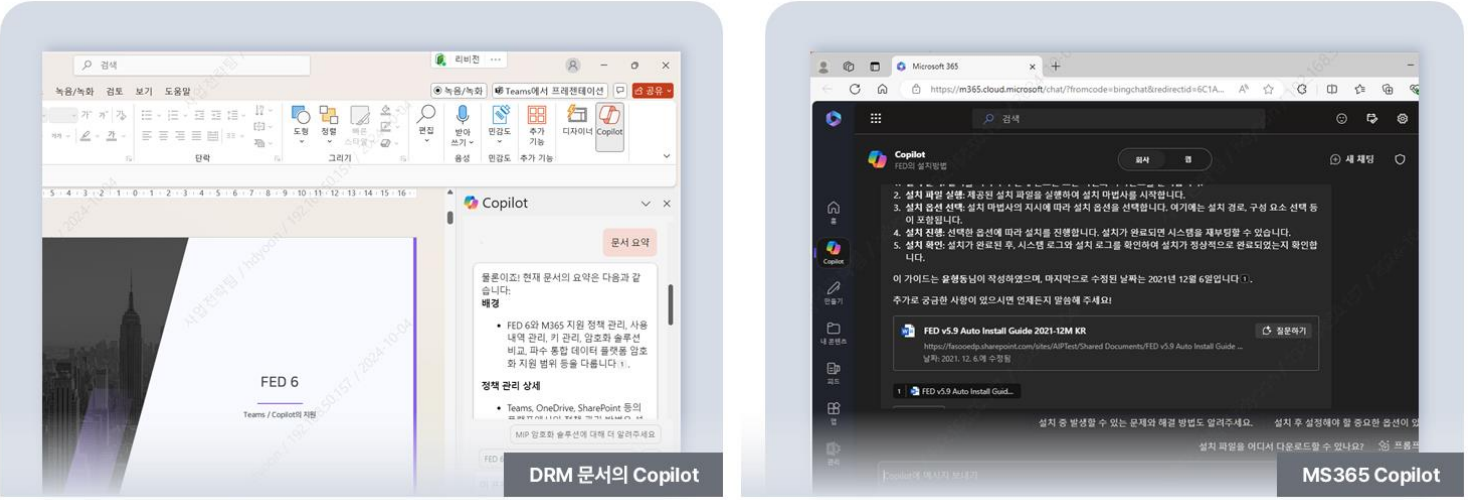
C	**Classified · 기밀** 정보공개법 제9조 1~4호 상당의 핵심 정보	고강도 암호화 + 접근 통제
S	**Sensitive · 민감** 내부 업무 문서·개인정보 포함 문서	권한 기반 암호화·이동 통제
O	**Open · 공개** 공개 가능한 일반 문서	비암호화 — AI 학습·연동 개방

Fasoo AI | FED v6 (Fasoo Enterprise DRM)가 등급별 정책을 실행 — 파일이 이동해도 통제가 따라갑니다.

Copyright© Fasoo AI All Rights Reserved.

암호화된 문서도, Copilot과 함께 일합니다

FED v6 — DRM 문서의 Copilot 활용 (좌) · MS365 Copilot 연동 (우), 실제 화면

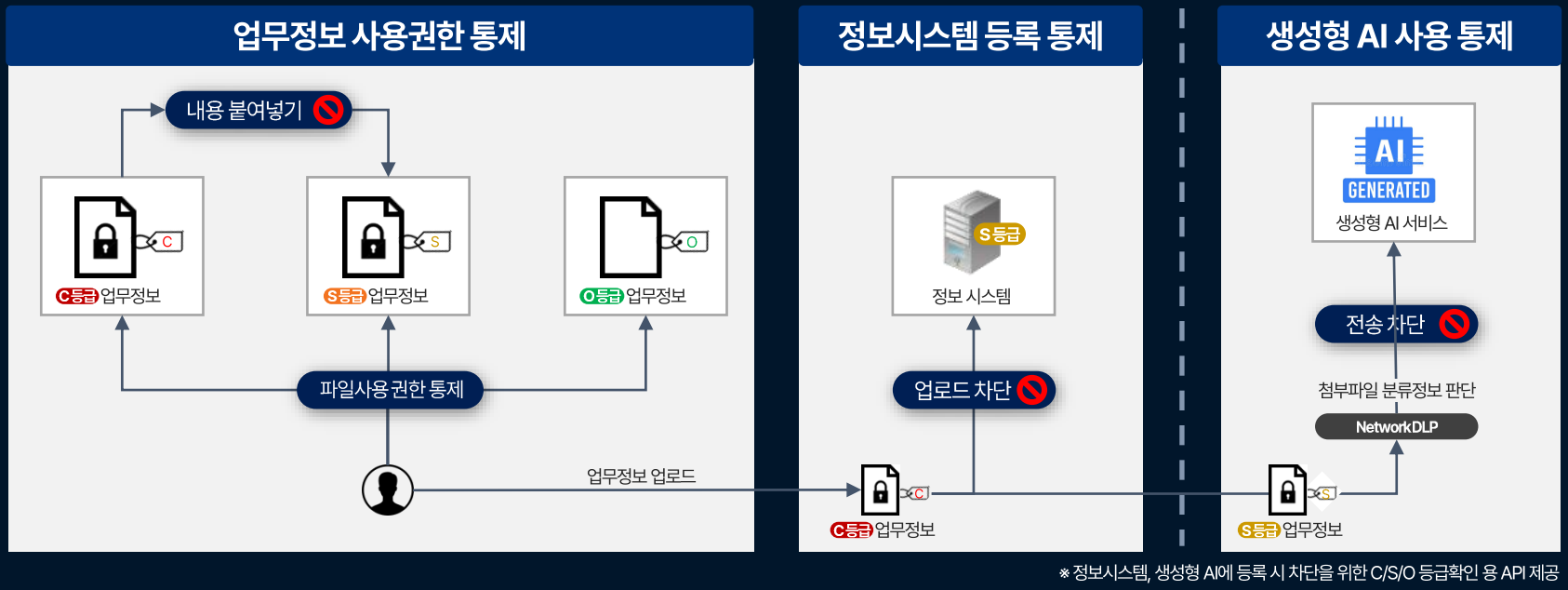


MIP 변환으로 Teams · OneDrive · Copilot에서 **보안을 유지한 채 활용** — 차등 보호는 생산성을 막지 않습니다.

Copyright© Fasoo AI All Rights Reserved.

분류 된 데이터에 대한 손쉬운 보안적용

분류된 **C/S/O 3등급**에 맞춰 기존 보안 인프라를 활용하여 통제가 가능합니다.



※정보시스템, 생성형 AI에 등록 시 차단을 위한 C/S/O 등급확인 용 API 제공

Fasoo AI | FED v6 (Fasoo Enterprise DRM)가 등급별 정책을 실행 — 파일이 이동해도 통제가 따라갑니다.

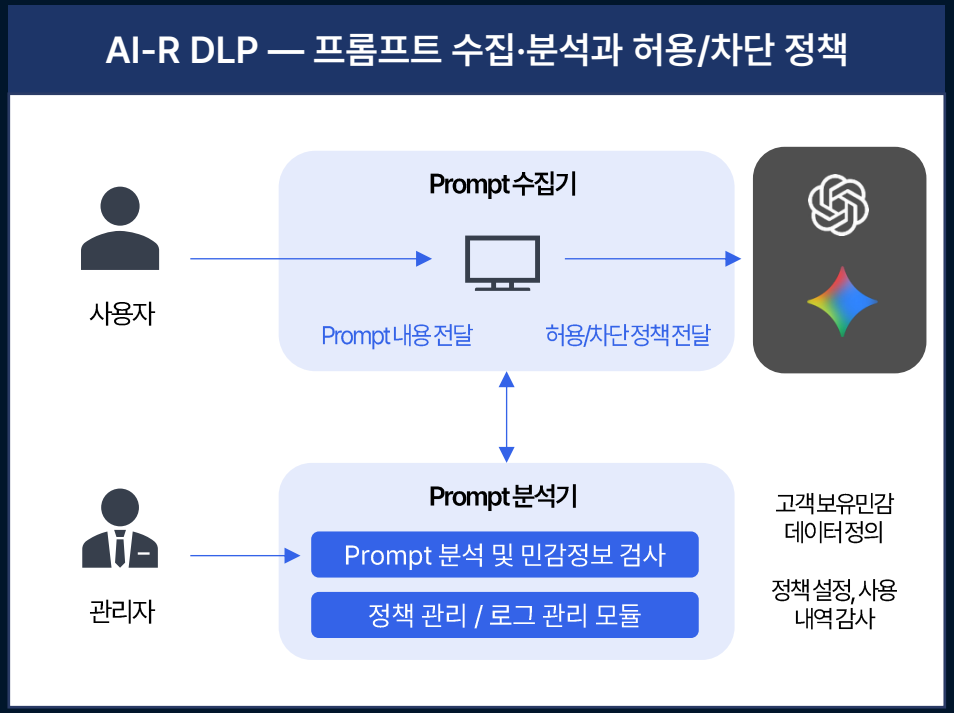
Copyright© Fasoo AI All Rights Reserved.

FASOO | AI

마지막 길목 — 프롬프트도 등급으로 통제합니다

- 프롬프트 · 첨부파일 실시간 검사
- C/S/O 규정 기반 허용 · 경고 · 차단
- 전송 전건 로깅, 이상행위 모니터링
- N/W 연계 · RBI · API — 유연한 적용

N2SF 정책상 **C·S 등급은 외부 AI 전송 금지** — 필터링은 의무입니다



Fasoo AI | AI-R DLP — ChatGPT · Gemini · Claude 지원

Copyright© Fasoo AI All Rights Reserved.

FASOO | AI

기업과 기관의 개인정보 보안 대응 실전

태세 관리

Copyrightⓒ Fasoo AI All Rights Reserved.

FASOO | AI

데이터 보안 태세 관리 DSPM
(Data Security Posture Management)

DSPM (Data Security Posture Management)은
클라우드 환경 및 서비스에서 조직의 데이터 보안 상태를
지속적으로 평가하고 관리하는 프레임워크를 지칭합니다.

DSPM은 데이터를 식별해 접근 제어, 암호화 등
위험 노출 여부를 점검하고,
보안 취약점과 컴플라이언스 미 준수 위험을 평가합니다

Gartner

Gartner는 **DSPM을 데이터 중심 보안의 혁신적인 분야**로 소개하며, 데이터 보안 상태를 관리하고 보안 및 규제 준수를 보장한다고 정의합니다.

IDC
Analyze the Future

IDC는 **DSPM을 클라우드 및 하이브리드 환경에서의 데이터 보안 상태를 관리**하기 위한 솔루션으로 설명합니다.

NIST
National Institute of Standards and Technology

NIST는 **DSPM을 데이터 보호 및 민감 정보 보안을 강화하기 위한 절차와 기술을 포함한 프레임워크**로 정의합니다.

CSA cloud security alliance®

CSA(Cloud Security Alliance)는 **DSPM을 클라우드 환경의 데이터 가시성과 보안 관리에 집중하는 솔루션**이라 설명합니다.

Copyright© Fasoo AI All Rights Reserved.

DSPM의 필요성

멀티 클라우드 및 SaaS 환경의 **4대 보안 포인트**

데이터 경계 상실 및 파편화

AWS, Azure, M365, 구글 Works, Slack, 로컬 PC로 데이터 분산

암묵적 섀도우 데이터 양산

개발자/임직원이 무단 복사·방치한 S3 버킷 및 구 버전 파일

과도한 과잉 권한

외부 공개 링크 설정, 퇴사자 계정 공유 권한 방치

기존 CSPM의 모니터링 한계

CSPM은 인프라 설정만 모니터링하며 '실제 데이터 내용' 파악 불가

Copyrightⓒ Fasoo AI All Rights Reserved.

DSPM의 필요성

DSPM 도입을 통한 **보안 패러다임의 전환**

인프라 중심에서 데이터 중심 보안으로

어디에 민감 정보가 존재하는지 데이터 자체에 집중 통제

정적 (Static) 점검'이 '동적 (Continuous) 태세 관리'로

데이터 생성·이동 시점 실시간 위협 모니터링

수동 감사'에서 '자동화된 리스크 교정'으로

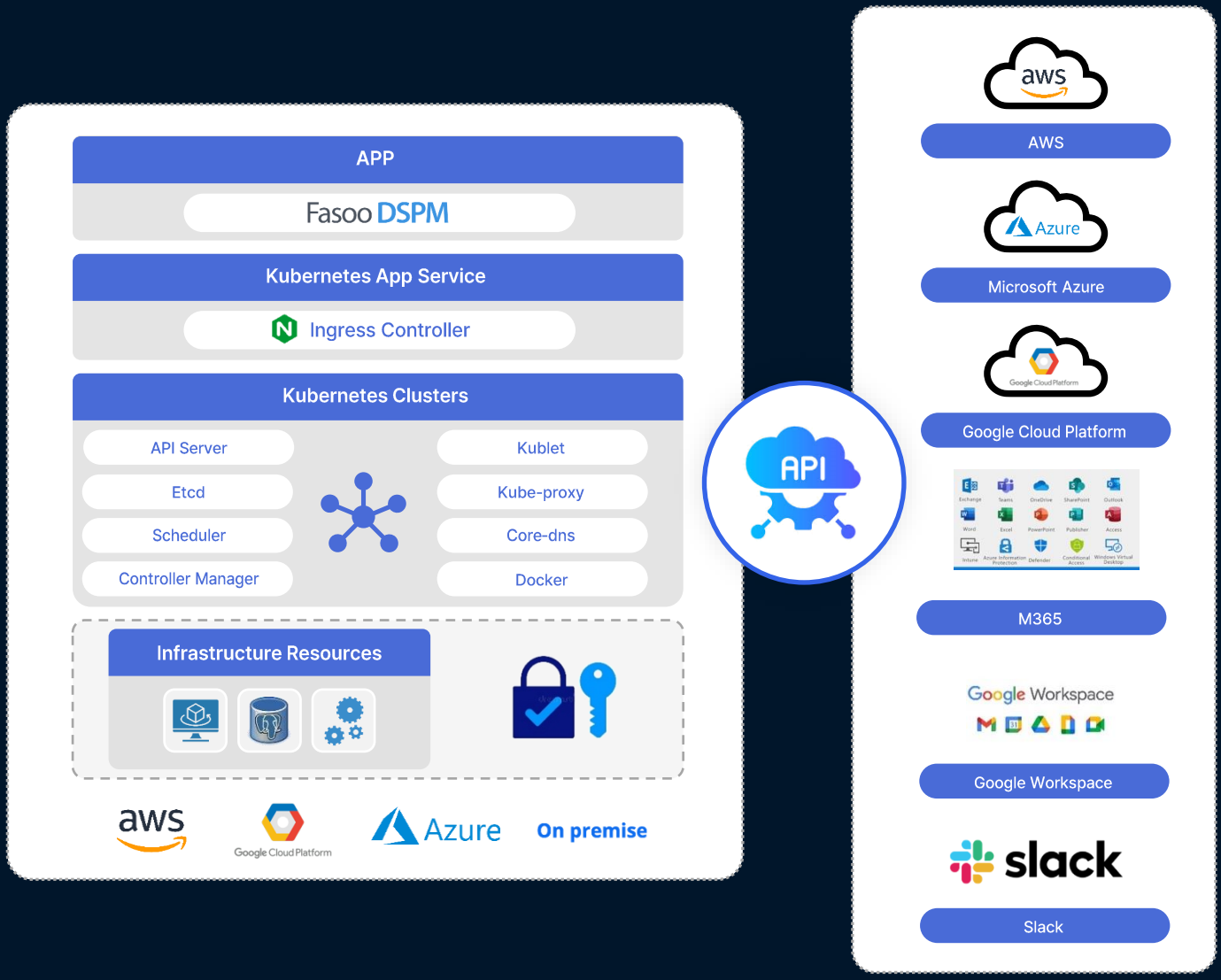
과도한 공유 권한 즉시 격리 및 자가 치유 (Self-Healing)

규제 준수 증적 '상시 자동화'

개인정보보호법 및 글로벌 규제 (GDPR) 대응 실시간 증빙

Copyrightⓒ Fasoo AI All Rights Reserved.

Fasoo DSPM의 필요성



Copyright© Fasoo AI All Rights Reserved.

Fasoo DSPM의 주요 기능



데이터 자산의 발견 및 분류

- 데이터 자산의 저장 위치 식별
- 식별 데이터의 유형 정의
- 민감도에 따른 데이터 분류



규정 준수 상태 확인

- 컴플라이언스 위반 활동에 대한 정보 제공
- 준수 상태 알림



보안 위험 평가 및 모니터링

- 저장 스토리지 위험 평가
- 민감 데이터와 스토리지 유형에 따른 위험 분석
- 보안 상태 모니터링



실시간 보안 태세 가시성 제공

- 데이터의 저장 위치에 따른 취약점 확인
- 데이터의 유통 경로 추적

Copyrightⓒ Fasoo AI All Rights Reserved.

Fasoo DSPM 이 제공하는 것

스토리지별 위험 수준 평가



컴플라이언스 위반 및 저장소 ACL 확인



Copyright© Fasoo AI All Rights Reserved.

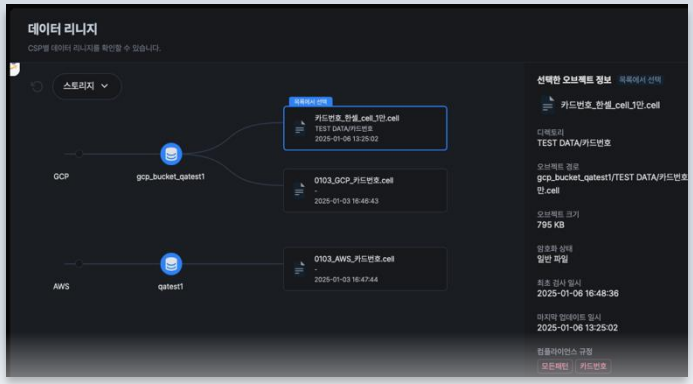
FASOO AI

Fasoo DSPM 이 제공하는 것

데이터 저장 위치 확인



유통 경로 추적



Copyright© Fasoo AI All Rights Reserved.

FASOO | AI

마지막 정리



분류 식별

문맥을 읽는 AI 검출로 개인정보를
전수 파악합니다
- 법 제29조의 출발점



차등 보호

C/S/O 등급별
암호화 + 프롬프트 통제
- 보안과 AI 생산성이 양립합니다



태세 관리

상시 추적으로
섀도우 데이터를 통제하고
72시간 의무에 대응합니다

Q&A | 도입 문의 · PoC 신청 · 컴플라이언스 진단 컨설팅

Copyright© Fasoo AI All Rights Reserved.

무엇이 달라지나 – 한눈에 비교

구분	전통적 방식 (일괄 통제)	3단계 프레임워크 (선순환)
식별	정규식 (오탐, 미탐 다수)	AI 문맥 식별 (고정밀)
보호	전사 일괄 암호화 (AI 마비)	C/S/O 차등 암호화 (AI 개방)
범위	온프레미스, PC 중심	PC + Multi Cloud + SaaS
관리	정적 (섀도우 데이터 방치)	동적 상시 (자동 탐지, 조치)
법적 대응	수동 증적 (리스크 노출)	실시간 증적 (감경 확보)

Copyright© Fasoo AI All Rights Reserved.

FASOO AI는 이렇게 발 맞춥니다.

STEP 1 식별	Fasoo Data Radar	PC·서버 전수 스캔 · 자동 분류 · 후처리
STEP 1 식별	AI-R Privacy	딥러닝 문맥 검출 — 문서 · 이미지 마스킹
STEP 2 보호	Fasoo Enterprise DRM	등급별 차등 암호화 — MS365 · Copilot 지원
STEP 2+ 통제	AI-R DLP	프롬프트 · 첨부 검사 — C/S/O 허용 · 차단
STEP 3 관리	Fasoo DSPM	에이전트리스 Multi-Cloud · SaaS 상시 감시

프레임워크가 먼저, 제품은 실행 수단입니다 — 독립 도입도, 단계별 확장도 가능합니다.

Copyright© Fasoo AI All Rights Reserved.

보안은 AI 혁신의 걸림돌이 아니라,
가속기 입니다.

통제 없는 AI 도입은 브레이크 없는 자동차와 같습니다.

공공 (N2SF)이 먼저 검증한 등급 기반 차등 통제가,

지속 가능한 AI 성장의 전제 조건입니다.

Copyright© Fasoo AI All Rights Reserved.

FASOO | AI